

## MATRIZ DE EVALUACIÓN PRAGMATIC COMPLETA

### Calificación de los 22 Indicadores CIA Triad bajo los 9 Criterios PRAGMATIC

#### CIA Triad Metrics Framework — España 2025

*"Una métrica que puntúa 27/27 en PRAGMATIC no existe. Una métrica que puntúa menos de 12/27 tampoco debería existir en un cuadro de mando serio. Entre ambos extremos vive la ingeniería real de la medición de la ciberseguridad."*

#### ESCALA DE PUNTUACIÓN

| Puntuación | Significado                                                  |
|------------|--------------------------------------------------------------|
| 3          | Cumple plenamente el criterio — sin reservas                 |
| 2          | Cumple parcialmente — con condiciones o limitaciones menores |
| 1          | Cumple de forma marginal — requiere mejora significativa     |
| 0          | No cumple — el criterio no se satisface                      |

**Puntuación total máxima por métrica:** 27 puntos

**Clase A (Óptima):** 24–27 | **Clase B (Buena):** 18–23 | **Clase C (Aceptable):** 12–17 | **Clase D (Revisar):** <12

#### Criterios PRAGMATIC:

- **P** — Predictivo: ¿Anticipa riesgos futuros o tendencias?
- **R** — Relevante: ¿Importa para las decisiones de negocio?
- **A** — Accionable: ¿Genera acciones concretas según el valor?
- **G** — Genuino: ¿Mide el fenómeno real sin proxies inadecuados?
- **M** — Medurable/Significativo: ¿Puede obtenerse con esfuerzo razonable?
- **A2** — Accurate/Preciso: ¿Tiene exactitud suficiente para su uso?
- **T** — Timely/Oportuno: ¿Está disponible cuando se necesita?
- **I** — Independiente: ¿Puede verificarse externamente?
- **C** — Cost-effective/Rentable: ¿El beneficio supera el coste de medición?

## TABLA MAESTRA DE EVALUACIÓN PRAGMATIC

### PILAR CONFIDENCIALIDAD (C)

#### C-01: Tasa de Cobertura MFA (M-C01a, M-C01b, M-C01c)

| Crterio             | Puntuación | Justificación detallada                                                                                                                                                                                                                  |
|---------------------|------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>P Predictivo</b> | 3          | Las cuentas sin MFA son el principal predictor de brecha por compromiso de credenciales. La cobertura < 70% predice alto riesgo de incidente en ventana de 90 días según datos Verizon DBIR 2025 (22% brechas por credenciales robadas). |
| <b>R Relevante</b>  | 3          | Directamente vinculada a NIS2 Art. 21(2)(i), ENS Op.acc.5 y las pérdidas más comunes por brecha. Interesa al CISO, al Consejo y al regulador por igual.                                                                                  |
| <b>A Accionable</b> | 3          | Cada decil de cobertura genera una acción específica: <50% = despliegue emergencia MFA; 50-80% = plan 30 días; 80-99% = seguimiento semanal; 100% = mantenimiento.                                                                       |
| <b>G Genuino</b>    | 2          | Mide la cobertura declarada de MFA, pero no su efectividad real frente a ataques (MFA fatigue, SIM swapping no se capturan en cobertura). M-C01c (bypass rate) corrige parcialmente.                                                     |
| <b>M Measurable</b> | 3          | Obtenible directamente de IAM platform/directorio activo en tiempo real. Cálculo trivial.                                                                                                                                                |
| <b>A2 Preciso</b>   | 3          | La fuente (IAM) es la fuente de verdad para estados de cuenta. Precisión > 99% con buena higiene del directorio.                                                                                                                         |
| <b>T Oportuno</b>   | 3          | Disponible en tiempo real o con latencia < 1 hora desde el IAM. Frecuencia mensual holgadamente satisfecha.                                                                                                                              |

|                        |       |                                                                                                                                                                     |
|------------------------|-------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>I Independiente</b> | 2     | Puede ser verificada por auditor externo accediendo al IAM. Sin embargo, el equipo de TI puede manipular el estado de las cuentas temporalmente antes de auditoría. |
| <b>C Rentable</b>      | 3     | Coste de extracción: < 1 hora técnico/mes. Valor: prevención de brecha media de \$4,44M. ROI de la métrica altísimo.                                                |
| <b>TOTAL</b>           | 25/27 | Clase A — Métrica de calidad óptima                                                                                                                                 |

**Áreas de mejora PRAGMATIC:** Complementar M-C01a con M-C01b (tipo de MFA) para capturar la brecha entre cobertura nominal y resistencia real al phishing.

*C-02: Índice de Madurez IAM (M-C02a, M-C02b, M-C02c, M-C02d)*

| Criterio            | Puntuación | Justificación detallada                                                                                                                                                                   |
|---------------------|------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>P Predictivo</b> | 3          | Las cuentas huérfanas (M-C02a) predicen compromiso de acceso post-baja. La tasa de revisión de privilegios predice el riesgo de privilege creep acumulado.                                |
| <b>R Relevante</b>  | 3          | El acceso indebido es el vector subyacente más frecuente en brechas internas (Verizon DBIR: 35% componente interno). Directamente vinculado a ENS, ISO 27001 y NIS2.                      |
| <b>A Accionable</b> | 3          | Orphan Account Rate > 5% → revisión inmediata del proceso de offboarding. Access Review < 100% → activar revisión trimestral. PAM Coverage < 80% → proyecto PAM urgente.                  |
| <b>G Genuino</b>    | 2          | M-C02d (Least Privilege Score) es el más genuino pero el más difícil de obtener. M-C02a puede subestimar cuentas huérfanas si el HR system no está integrado con IAM.                     |
| <b>M Medurable</b>  | 2          | M-C02a y M-C02c son directamente medibles. M-C02d requiere análisis de derechos efectivos vs. derechos necesarios, que demanda herramientas IGA (Identity Governance and Administration). |
| <b>A2 Preciso</b>   | 2          | La precisión depende críticamente de la calidad del directorio activo y la integración HR-IAM. En organizaciones con múltiples directorios, el error puede ser significativo.             |
| <b>T Oportuno</b>   | 3          | Disponible con frecuencia mensual/trimestral. Aceptable para el ritmo de revisión de accesos.                                                                                             |

|                        |       |                                                                                                                                                                       |
|------------------------|-------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>I Independiente</b> | 2     | Verificable por auditor con acceso al IAM. La revisión de privilegios efectivos requiere acceso especializado que no siempre está disponible para auditores externos. |
| <b>C Rentable</b>      | 2     | M-C02a y M-C02c: coste bajo. M-C02d: requiere herramienta IGA con coste no trivial. Justificable por valor preventivo en grandes organizaciones.                      |
| <b>TOTAL</b>           | 22/27 | Clase B — Métrica de buena calidad                                                                                                                                    |

**Áreas de mejora PRAGMATIC:** La genuinidad y precisión mejoran con integración HR-IAM automatizada. M-C02d requiere inversión en herramienta IGA para alcanzar Clase A.

**C-03: Cobertura de Cifrado en Reposo (M-C03a, M-C03b, M-C03c)**

| <b>Criterio</b>     | <b>Puntuación</b> | <b>Justificación detallada</b>                                                                                                                                                                    |
|---------------------|-------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>P Predictivo</b> | 2                 | Predice el impacto potencial de una brecha (datos cifrados = brecha sin valor para atacante), pero no predice la probabilidad de la brecha en sí. Valor predictivo indirecto.                     |
| <b>R Relevante</b>  | 3                 | Obligatoria bajo RGPD Art. 32(1) (a) y ENS Mp.si.2. La ausencia de cifrado convierte cualquier brecha en una notificación obligatoria a la AEPD.                                                  |
| <b>A Accionable</b> | 3                 | Repositorios no cifrados → acción de cifrado inmediata por categoría de riesgo. Algoritmos legacy → migración planificada con SLA.                                                                |
| <b>G Genuino</b>    | 2                 | La cobertura de cifrado mide la existencia del control, no su efectividad. Un cifrado con gestión de claves deficiente (M-C03c) puede ser inútil. El score compuesto captura mejor la genuinidad. |
| <b>M Measurable</b> | 2                 | La cobertura de cifrado puede requerir herramientas CSPM (Cloud Security Posture Management) o DSPM (Data Security Posture Management) que no todas las organizaciones tienen.                    |
| <b>A2 Preciso</b>   | 2                 | Los scanners de configuración pueden tener cobertura incompleta en entornos híbridos o legacy con sistemas no estándar.                                                                           |
| <b>T Oportuno</b>   | 2                 | Frecuencia mensual alcanzable con herramientas CSPM/DSPM. Sin estas herramientas, la medición manual es trimestral en el mejor caso.                                                              |

|                        |       |                                                                                                                                                                                     |
|------------------------|-------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>I Independiente</b> | 2     | Verificable mediante auditoría técnica. El acceso a los entornos requerido puede limitar la independencia en auditorías externas de organizaciones con datos muy sensibles.         |
| <b>C Rentable</b>      | 2     | Coste de CSPM/DSPM es significativo. Para organizaciones grandes, el valor justifica la inversión. Para PYMEs, puede ser desproporcionado; alternativas más económicas disponibles. |
| <b>TOTAL</b>           | 20/27 | Clase B — Métrica de buena calidad                                                                                                                                                  |

**C-04: Índice de Cripto-Agilidad PQC (M-C04a, M-C04b, M-C04c)**

| Criterio            | Puntuación | Justificación detallada                                                                                                                                                                                                           |
|---------------------|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>P Predictivo</b> | 3          | Es intrínsecamente predictivo: anticipa el riesgo de que los datos cifrados hoy sean descifrados en 5-15 años cuando existan ordenadores cuánticos suficientemente potentes. Único indicador forward-looking de todo el conjunto. |
| <b>R Relevante</b>  | 2          | Alta relevancia para infraestructuras críticas, defensa y finanzas. Relevancia media para PYMEs. La urgencia no es inmediata, pero el coste de la inacción se acumula silenciosamente con HNDL.                                   |
| <b>A Accionable</b> | 2          | M-C04c (Migration Progress Score) genera acciones claras. M-C04a (inventario) y M-C04b (exposición) son precondiciones para la acción. La cadena de acción es correcta pero lenta en implementación.                              |
| <b>G Genuino</b>    | 2          | M-C04b captura la exposición real a algoritmos Q-vulnerables. Sin embargo, el riesgo cuántico real depende del horizonte temporal de los datos (datos con vida útil de 10+ años vs. datos efímeros).                              |
| <b>M Medurable</b>  | 2          | Requiere herramientas especializadas de escaneo criptográfico (Cryptosense, IBM Guardium Cryptography). No universalmente disponibles. El inventario manual es tedioso pero posible.                                              |
| <b>A2 Preciso</b>   | 1          | La precisión del inventario criptográfico es intrínsecamente limitada en sistemas legacy, librerías embebidas y firmware de dispositivos. Muchos algoritmos criptográficos son invisibles sin herramientas especializadas.        |

|                        |       |                                                                                                                                                                                                         |
|------------------------|-------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>T Oportuno</b>      | 3     | Frecuencia semestral es perfectamente adecuada para una amenaza que tiene horizonte temporal de años. No requiere tiempo real.                                                                          |
| <b>I Independiente</b> | 2     | Verificable por auditores con herramientas especializadas. El nivel de expertise requerido limita la independencia real.                                                                                |
| <b>C Rentable</b>      | 2     | Coste de inventario criptográfico especializado es alto. El valor preventivo es enorme a largo plazo pero difícil de cuantificar a corto. Justificado para organizaciones con datos de vida útil larga. |
| <b>TOTAL</b>           | 19/27 | Clase B — Métrica de buena calidad                                                                                                                                                                      |

**Nota:** La puntuación de Preciso (1) refleja la dificultad intrínseca del problema, no un defecto del indicador. Es la métrica con mayor impacto futuro del conjunto, a pesar de ser la menos precisa hoy.

**C-05: Tasa de Cobertura DLP (M-C05a, M-C05b, M-C05c)**

| <b>Criterio</b>        | <b>Puntuación</b> | <b>Justificación detallada</b>                                                                                                                                                                                                             |
|------------------------|-------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>P Predictivo</b>    | 2                 | La baja cobertura DLP predice mayor probabilidad de exfiltración no detectada, pero el DLP no previene la brecha inicial. Valor predictivo moderado.                                                                                       |
| <b>R Relevante</b>     | 3                 | Directamente vinculado a RGPD Art. 25 (privacidad por diseño) y NIS2. La exfiltración de datos es el segundo impacto más costoso tras la interrupción del servicio (IBM 2025).                                                             |
| <b>A Accionable</b>    | 3                 | DLP Coverage < 70% → ampliar cobertura a canales faltantes. False Positive Rate > 30% → reconfiguración de reglas. Block Rate inusualmente bajo → revisión de política DLP.                                                                |
| <b>G Genuino</b>       | 2                 | La cobertura de canales no garantiza la efectividad de las reglas DLP. Un DLP con reglas pobremente configuradas puede tener 100% de cobertura y 0% de efectividad real. M-C05c (falsos positivos) es el indicador de calidad más genuino. |
| <b>M Measurable</b>    | 3                 | Las plataformas DLP generan estadísticas nativas detalladas. Coste de extracción mínimo una vez implementada la solución.                                                                                                                  |
| <b>A2 Preciso</b>      | 2                 | La precisión depende de la clasificación previa de datos. Sin clasificación de datos adecuada, el DLP no puede distinguir datos sensibles de no sensibles con fiabilidad.                                                                  |
| <b>T Oportuno</b>      | 3                 | Disponible en tiempo casi real desde la plataforma DLP. Informes semanales son automáticos en todas las soluciones maduras.                                                                                                                |
| <b>I Independiente</b> | 2                 | Verificable por auditor con acceso a la consola DLP. Los logs de eventos DLP son difícilmente manipulables a posteriori.                                                                                                                   |

|                   |       |                                                                                                                                                                     |
|-------------------|-------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>C Rentable</b> | 2     | El coste de la plataforma DLP es el principal driver. Una vez implementada, el coste de la métrica es marginal. Sin DLP, la métrica no existe y tampoco el control. |
| <b>TOTAL</b>      | 22/27 | Clase B — Métrica de buena calidad                                                                                                                                  |

*C-06: Índice de Gobernanza Shadow AI (M-C06a, M-C06b, M-C06c)*

| Criterio            | Puntuación | Justificación detallada                                                                                                                                                                                                                                         |
|---------------------|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>P Predictivo</b> | 3          | El Shadow AI no inventariado es un riesgo de exfiltración silenciosa. Cada herramienta IA no catalogada puede estar procesando datos confidenciales en servicios externos sin evaluación de riesgos. Alta capacidad predictiva del riesgo futuro.               |
| <b>R Relevante</b>  | 3          | El 63% de organizaciones sin política de IA generativa (IBM 2025) es una cifra que convierte este indicador en uno de los más urgentes para 2025-2026. EU AI Act comenzó aplicación en 2025.                                                                    |
| <b>A Accionable</b> | 3          | Shadow AI Rate bajo → auditoría de herramientas en uso + política inmediata. Policy Maturity < 2 → redacción y aprobación de política en plazo definido.                                                                                                        |
| <b>G Genuino</b>    | 1          | Este es el talón de Aquiles del indicador: la detección de Shadow AI es intrínsecamente incompleta. El CASB detecta tráfico web y apps cloud, pero no IA integrada en código, extensiones de navegador o uso local de modelos. Lo que no se detecta no se mide. |
| <b>M Medurable</b>  | 2          | Requiere CASB y capacidad de análisis de tráfico. La medición del shadow por definición siempre es parcial. M-C06b (madurez de política) es más medible que la detección real.                                                                                  |
| <b>A2 Preciso</b>   | 1          | La naturaleza del Shadow IT/AI implica que cualquier medición de cobertura subestima el fenómeno real. La precisión es estructuralmente limitada.                                                                                                               |
| <b>T Oportuno</b>   | 2          | El inventario trimestral es razonable. La detección en tiempo real requiere CASB con capacidades específicas de IA.                                                                                                                                             |

|                        |       |                                                                                                                                                                            |
|------------------------|-------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>I Independiente</b> | 2     | La política (M-C06b) es verificable. La cobertura de inventario es verificable con acceso al CASB. La completitud del inventario es no verificable por definición.         |
| <b>C Rentable</b>      | 2     | Coste del CASB más análisis especializado es significativo. La política (M-C06b) tiene coste bajo. El coste de no medir (brecha por Shadow AI) es potencialmente muy alto. |
| <b>TOTAL</b>           | 19/27 | Clase B — Métrica de buena calidad                                                                                                                                         |

**Nota crítica:** Las puntuaciones bajas en Genuino y Preciso no invalidan el indicador; son una característica de la naturaleza del objeto medido. La recomendación es combinar M-C06a con M-C06b y M-C06c para compensar las limitaciones de cada sub-métrica individual.

## PILAR INTEGRIDAD (I)

### I-01: Tasa de Cobertura FIM (M-I01a, M-I01b, M-I01c)

| Criterio            | Puntuación | Justificación detallada                                                                                                                                                                                   |
|---------------------|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>P Predictivo</b> | 2          | La cobertura FIM no predice ataques, pero detecta sus efectos tempranos. M-I01b (tiempo de detección) sí tiene valor predictivo: tiempos largos predicen mayor impacto potencial del incidente.           |
| <b>R Relevante</b>  | 3          | PCI-DSS lo exige como control obligatorio. ENS lo requiere para sistemas de alta criticidad. La detección de modificaciones no autorizadas es fundamental para la respuesta a incidentes.                 |
| <b>A Accionable</b> | 3          | FIM Coverage < 80% → despliegue prioritario en sistemas críticos no cubiertos. FIM Detection Time > 60 min → revisar configuración y conectividad SIEM.                                                   |
| <b>G Genuino</b>    | 3          | FIM mide directamente lo que declara medir: la ocurrencia de modificaciones en ficheros. Es uno de los indicadores más genuinos del conjunto. Los falsos positivos son el principal riesgo de genuinidad. |
| <b>M Measurable</b> | 3          | Las herramientas FIM (Tripwire, Wazuh, AIDE) generan métricas nativas. Cálculo automático y sencillo una vez implementada la herramienta.                                                                 |
| <b>A2 Preciso</b>   | 3          | La detección de modificaciones es binaria y objetiva. La precisión es alta. Los falsos positivos se gestionan con líneas base adecuadas.                                                                  |
| <b>T Oportuno</b>   | 3          | FIM opera en tiempo real o near-real-time. M-I01b es medible por evento. M-I01a mensual. Frecuencias perfectamente adecuadas.                                                                             |

|                        |       |                                                                                                                                                                        |
|------------------------|-------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>I Independiente</b> | 2     | Verificable por auditor con acceso a la herramienta FIM. Sin embargo, un atacante con acceso privilegiado podría desactivar el agente FIM antes de modificar ficheros. |
| <b>C Rentable</b>      | 3     | Herramientas FIM open source (AIDE, Wazuh) tienen coste bajo. Incluso las comerciales son de coste moderado. El valor preventivo y forense es alto.                    |
| <b>TOTAL</b>           | 25/27 | Clase A — Métrica de calidad óptima                                                                                                                                    |

*I-02: Tiempo Mediano de Parcheo (TMPVC) (M-I02a, M-I02b, M-I02c, M-I02d)*

| Criterio             | Puntuación | Justificación detallada                                                                                                                                                                                                                                                   |
|----------------------|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>P Predictivo</b>  | 3          | La antigüedad de vulnerabilidades sin parche es el predictor más potente de explotación exitosa. La probabilidad de explotación aumenta exponencialmente en las primeras 2 semanas tras publicación (EPSS). TMPVC es el indicador predictivo de referencia en integridad. |
| <b>R Relevante</b>   | 3          | Exigida como métrica explícita por NIS2, DORA y ENS. El 28% de organizaciones EU tardando más de 3 meses en parchear críticos (ENISA 2025) demuestra que la brecha es real y relevante.                                                                                   |
| <b>A Accionable</b>  | 3          | TMPVC > 30 días → activar proceso de gestión de excepciones + compensatory controls. CVE > 30 días sin parche = 0 → alerta automática con escalado al CISO.                                                                                                               |
| <b>G Genuino</b>     | 3          | Mide exactamente lo que declara: el tiempo real de exposición. La fecha de publicación CVE y la fecha de parcheo son datos objetivos y auditables.                                                                                                                        |
| <b>M Medasurable</b> | 3          | Extractable de vulnerability scanners (Tenable, Qualys) con precisión automática. Disponible en cualquier organización con scanner.                                                                                                                                       |
| <b>A2 Preciso</b>    | 2          | La precisión depende de la frecuencia de los scans de vulnerabilidad. Un scan semanal puede sobreestimar el TMPVC hasta 7 días. El uso de agentes continuos mejora la precisión a horas.                                                                                  |

|                        |       |                                                                                                                                                                                           |
|------------------------|-------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>T Oportuno</b>      | 3     | Disponible semanalmente con cualquier scanner. Con agentes continuos, en tiempo real. Frecuencia perfectamente adecuada para la dinámica de las vulnerabilidades.                         |
| <b>I Independiente</b> | 3     | Los CVE son publicados por terceros (NVD, CISA). La fecha de parcheo puede ser verificada por auditor con acceso al scanner o al sistema de gestión de cambios. Dificilmente manipulable. |
| <b>C Rentable</b>      | 3     | Los vulnerability scanners ya son herramientas estándar. El coste marginal de extraer TMPVC es prácticamente cero. El valor (prevención de brecha) es máximo.                             |
| <b>TOTAL</b>           | 26/27 | Clase A — Métrica de calidad óptima ★                                                                                                                                                     |

**Nota destacada:** TMPVC obtiene la puntuación más alta del conjunto (26/27). Es el indicador de referencia para cualquier organización que empiece a construir su sistema de métricas de integridad.

*I-03: Índice de Integridad de la Cadena de Suministro (M-I03a, M-I03b, M-I03c)*

| Criterio            | Puntuación | Justificación detallada                                                                                                                                                                                                         |
|---------------------|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>P Predictivo</b> | 2          | La ausencia de SBOM y verificación de artefactos predice mayor exposición a ataques de supply chain. Sin embargo, la predicción es indirecta: un SBOM completo no elimina el riesgo si los componentes tienen vulnerabilidades. |
| <b>R Relevante</b>  | 3          | El 30% de brechas globales por terceros en 2025 (Verizon DBIR) y el EU CRA que mandará SBOM hacen que sea uno de los indicadores más urgentes del conjunto para 2026-2027.                                                      |
| <b>A Accionable</b> | 3          | SBOM Coverage < 20% → plan de implementación SBOM en pipelines CI/CD. Artifact Verification Rate < 100% → obligar verificación criptográfica en CI/CD gate. Third-Party Breach Rate > 30% → auditoría de proveedores críticos.  |
| <b>G Genuino</b>    | 2          | M-I03b (verificación de artefactos) es genuino. M-I03a (SBOM) mide la existencia del inventario, no la integridad real de los componentes. Un SBOM desactualizado puede tener precisión nula.                                   |
| <b>M Measurable</b> | 2          | M-I03b es medible en el pipeline CI/CD. M-I03a requiere herramientas SBOM (Syft, SPDX) aún no universales. M-I03c requiere categorización de incidentes por origen, no siempre disponible.                                      |
| <b>A2 Preciso</b>   | 2          | La precisión del SBOM depende de su frecuencia de actualización. Los SBOMs estáticos son imprecisos por definición. Los SBOMs generados dinámicamente en cada build son más precisos.                                           |

|                        |       |                                                                                                                                                                                                                   |
|------------------------|-------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>T Oportuno</b>      | 2     | M-I03b (pipeline): tiempo real.<br>M-I03a (trimestral): aceptable.<br>M-I03c (anual): lento para<br>detección operativa, aceptable<br>para análisis estratégico.                                                  |
| <b>I Independiente</b> | 2     | M-I03b verificable con acceso al<br>pipeline. M-I03a verificable con<br>acceso al repositorio de SBOMs.<br>M-I03c requiere acceso al<br>registro de incidentes con<br>categorización adecuada.                    |
| <b>C Rentable</b>      | 2     | La generación de SBOM en el<br>pipeline tiene coste de<br>implementación inicial<br>moderado. Una vez integrado, el<br>coste marginal es bajo. El<br>beneficio normativo (EU CRA)<br>añade valor de cumplimiento. |
| <b>TOTAL</b>           | 20/27 | Clase B — Métrica de buena<br>calidad                                                                                                                                                                             |

*I-04: Tasa de Firma Digital (M-I04a, M-I04b, M-I04c)*

| Criterio            | Puntuación | Justificación detallada                                                                                                                                                                     |
|---------------------|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>P Predictivo</b> | 2          | La baja cobertura de firma digital predice riesgo de repudio de transacciones y dificultad en investigación forense. Valor predictivo moderado y orientado a consecuencias legales.         |
| <b>R Relevante</b>  | 3          | Alta relevancia en sectores regulados (financiero, AAPP, salud). eIDAS 2 eleva la obligatoriedad. La firma cualificada es requisito en numerosos procesos regulados.                        |
| <b>A Accionable</b> | 3          | PKI Health < 100% → proceso de renovación inmediata. Certificate Expiry < 30 días de antelación → alertas automáticas. Signature Coverage < 80% → auditoría de procesos críticos sin firma. |
| <b>G Genuino</b>    | 3          | La firma digital es un control técnico objetivo y verificable criptográficamente. Es uno de los indicadores más genuinos del conjunto.                                                      |
| <b>M Medurable</b>  | 3          | Medible mediante herramientas de gestión PKI y Certificate Transparency. Coste de extracción bajo con herramientas de monitorización de certificados (Venafi, Sectigo).                     |
| <b>A2 Preciso</b>   | 3          | Los estados de certificados son binarios (válido/expirado/revocado) y objetivos. La precisión es intrínsecamente alta.                                                                      |
| <b>T Oportuno</b>   | 3          | M-I04b monitorizable en tiempo real. M-I04a mensual. M-I04c mensual. Todas las frecuencias son alcanzables con herramientas estándar.                                                       |

|                        |       |                                                                                                                                                                                        |
|------------------------|-------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>I Independiente</b> | 3     | Los certificados cualificados son emitidos por Prestadores de Servicios de Confianza (TSP) acreditados. Su estado es verificable públicamente mediante OCSP/CRL. Independencia máxima. |
| <b>C Rentable</b>      | 3     | Las herramientas de monitorización PKI tienen coste moderado-bajo. El valor del cumplimiento eIDAS y la prevención de disputas legales hace el ROI muy favorable.                      |
| <b>TOTAL</b>           | 26/27 | Clase A — Métrica de calidad óptima ★                                                                                                                                                  |

### I-05: Índice de Integridad de Logs (M-I05a, M-I05b, M-I05c)

| Criterio            | Puntuación | Justificación detallada                                                                                                                                                                                                        |
|---------------------|------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>P Predictivo</b> | 2          | Los logs incompletos predicen dificultad en investigación forense post-incidente. Valor predictivo indirecto: no predice incidentes, sino la capacidad de respuesta ante ellos.                                                |
| <b>R Relevante</b>  | 3          | NIS2, DORA y ENS son explícitos en sus requisitos de logging. La capacidad forense depende directamente de la calidad de los logs. Alta relevancia regulatoria y operacional.                                                  |
| <b>A Accionable</b> | 3          | Log Centralization < 80% → identificar sistemas sin cobertura y desplegar agentes. Retention < 12 meses → revisar política de retención y ampliar almacenamiento. Integrity Verification < 1 → reactivar proceso verificación. |
| <b>G Genuino</b>    | 2          | M-I05a mide la centralización, no la completitud de los logs. Un sistema enviando logs pero con configuración incorrecta puede contar como "centralizado" sin serlo realmente.                                                 |
| <b>M Measurable</b> | 3          | Directamente medible desde la consola SIEM. Las plataformas modernas (Splunk, Sentinel) generan estas estadísticas de forma nativa.                                                                                            |
| <b>A2 Preciso</b>   | 2          | La precisión de M-I05a depende del inventario de sistemas. Si el inventario está incompleto, el denominador está subestimado y la cobertura se sobreestima.                                                                    |
| <b>T Oportuno</b>   | 3          | Disponible en tiempo real desde el SIEM. Todas las frecuencias son alcanzables.                                                                                                                                                |

|                        |       |                                                                                                                                                                                                         |
|------------------------|-------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>I Independiente</b> | 2     | Verificable por auditor con acceso al SIEM. La inmutabilidad de los logs (M-I05c) es el criterio más difícil de verificar de forma independiente en sistemas sin blockchain o timestamping cualificado. |
| <b>C Rentable</b>      | 2     | El SIEM es la inversión principal. Una vez implementado, el coste marginal de estas métricas es mínimo. El coste del SIEM es alto pero ya justificado por múltiples otros indicadores.                  |
| <b>TOTAL</b>           | 22/27 | Clase B — Métrica de buena calidad                                                                                                                                                                      |

## PILAR DISPONIBILIDAD (A)

### A-01: Tiempo Medio de Detección (MTTD) (M-A01a, M-A01b, M-A01c)

| Criterio            | Puntuación | Justificación detallada                                                                                                                                                                                                            |
|---------------------|------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>P Predictivo</b> | 3          | El MTTD histórico es el predictor más potente del coste futuro de un incidente: cada día de MTTD por encima de 60 días añade aproximadamente \$18.300 de coste (IBM 2025). Permite predecir el coste de la inacción con precisión. |
| <b>R Relevante</b>  | 3          | La métrica de referencia global en disponibilidad. Directamente vinculada a costes, cumplimiento NIS2 (notificación 24h/72h) y decisiones de inversión en SOC/SIEM.                                                                |
| <b>A Accionable</b> | 3          | MTTD > 90 días → inversión urgente en capacidades de detección (SOC, SIEM, EDR). Automated Detection Rate < 50% → revisar cobertura de agentes y reglas de detección. SOC Coverage < 24x7 → MDR o ampliación horaria.              |
| <b>G Genuino</b>    | 2          | El MTTD calculado retrospectivamente puede estar sesgado por incidentes que nunca se detectan (los más graves en términos de exposición). El MTTD solo mide los incidentes detectados, no los no detectados.                       |
| <b>M Medurable</b>  | 3          | Calculable desde el ITSM/SOAR con timestamps de inicio estimado del incidente y fecha de detección. Automático en plataformas SOAR maduras.                                                                                        |
| <b>A2 Preciso</b>   | 2          | La fecha de inicio del incidente a menudo se estima retrospectivamente mediante análisis forense, introduciendo incertidumbre. La fecha de detección es precisa; la fecha de inicio no siempre.                                    |

|                        |       |                                                                                                                                                                                         |
|------------------------|-------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>T Oportuno</b>      | 3     | Calculable mensualmente desde los registros de incidentes. Disponible con la frecuencia requerida para toma de decisiones.                                                              |
| <b>I Independiente</b> | 2     | Los registros de ITSM son verificables por auditor. Sin embargo, la estimación del inicio del incidente requiere expertise forense, lo que limita la verificación independiente simple. |
| <b>C Rentable</b>      | 3     | Se extrae de datos ya existentes en el ITSM sin coste adicional. El valor informacional para justificar inversiones en SOC/SIEM es extraordinariamente alto.                            |
| <b>TOTAL</b>           | 24/27 | Clase A — Métrica de calidad óptima                                                                                                                                                     |

#### A-02: Tiempo Medio de Respuesta y Contención (MTTR/MTTC) (M-A02a-d)

| Criterio               | Puntuación | Justificación detallada                                                                                                                                                                                          |
|------------------------|------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>P Predictivo</b>    | 2          | El MTTR histórico predice la capacidad de respuesta futura. Pero no predice la ocurrencia de incidentes. Valor predictivo operacional moderado.                                                                  |
| <b>R Relevante</b>     | 3          | NIS2 y DORA establecen plazos obligatorios de notificación que dependen directamente de MTTR/MTTC. Incumplimiento = sanción. Alta relevancia regulatoria.                                                        |
| <b>A Accionable</b>    | 3          | MTTC > 24h → revisar playbooks y capacidades de contención técnica. Notification Compliance < 100% → revisar proceso de escalado y criterios de notificabilidad.                                                 |
| <b>G Genuino</b>       | 3          | Los timestamps de detección, contención y resolución son eventos objetivos registrados en el ITSM. Alta genuinidad.                                                                                              |
| <b>M Medurable</b>     | 3          | Directamente calculable desde ITSM/SOAR con timestamps de eventos de incidente.                                                                                                                                  |
| <b>A2 Preciso</b>      | 3          | Las fechas de detección y resolución son precisas por definición (registros del sistema). La contención es el evento más subjetivo (¿cuándo se considera "contenido"?), requiere definición clara en el proceso. |
| <b>T Oportuno</b>      | 3          | Disponible por evento y en estadísticas mensuales. Perfectamente oportuno.                                                                                                                                       |
| <b>I Independiente</b> | 3          | Los registros de ITSM son auditables por terceros. La notificación regulatoria (M-A02c) deja trazas en los registros de INCIBE/CCN, verificables de forma completamente independiente.                           |

|                   |       |                                                                                                   |
|-------------------|-------|---------------------------------------------------------------------------------------------------|
| <b>C Rentable</b> | 3     | Sin coste adicional una vez implementado ITSM/SOAR. El valor regulatorio y operacional es máximo. |
| <b>TOTAL</b>      | 26/27 | Clase A — Métrica de calidad óptima ★                                                             |

**A-03: Cumplimiento de RTO/RPO (M-A03a, M-A03b, M-A03c, M-A03d)**

| Criterio            | Puntuación | Justificación detallada                                                                                                                                                                                                           |
|---------------------|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>P Predictivo</b> | 3          | El RTO/RPO Test Compliance Rate es un predictor directo de la capacidad real de recuperación en un incidente real. Un RTO que no se alcanza en prueba predice inactividad prolongada en el incidente real.                        |
| <b>R Relevante</b>  | 3          | DORA Art. 12 establece requisitos explícitos de RTO/RPO para el sector financiero. ISO 22301 los requiere para todo sistema de continuidad. Son las métricas de continuidad de negocio más reconocidas universalmente.            |
| <b>A Accionable</b> | 3          | RTO Definition Coverage < 100% → completar BIA (Business Impact Analysis). RTO Test Compliance < 80% → revisar arquitectura de recuperación y capacidades técnicas.                                                               |
| <b>G Genuino</b>    | 3          | Los resultados de pruebas DRP son mediciones directas y objetivas. El tiempo real de recuperación en un ejercicio es un dato genuino e inmanipulable.                                                                             |
| <b>M Measurable</b> | 3          | Los ejercicios generan datos directos de tiempo. La definición de RTO/RPO es documentable.                                                                                                                                        |
| <b>A2 Preciso</b>   | 2          | Los ejercicios en entorno controlado pueden no replicar exactamente las condiciones de un incidente real (mayor presión, sistemas degradados, equipos incompletos). Existe un sesgo de optimismo en los resultados de ejercicios. |
| <b>T Oportuno</b>   | 3          | Frecuencia trimestral para pruebas, semestral para revisión de definiciones. Adecuado para la dinámica de continuidad de negocio.                                                                                                 |

|                        |       |                                                                                                                                                                                                                    |
|------------------------|-------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>I Independiente</b> | 2     | Los informes de ejercicios son verificables por auditor. DORA requiere auditoría de las pruebas de resiliencia en entidades significativas. La independencia total requiere un observador externo en el ejercicio. |
| <b>C Rentable</b>      | 2     | Los ejercicios DRP tienen coste operacional (tiempo de técnicos, entornos de test). Justificado por el valor de verificación real de la continuidad.                                                               |
| <b>TOTAL</b>           | 24/27 | Clase A — Métrica de calidad óptima                                                                                                                                                                                |

**A-04: Disponibilidad Efectiva de Servicios (M-A04a, M-A04b, M-A04c)**

| Criterio            | Puntuación | Justificación detallada                                                                                                                                                                      |
|---------------------|------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>P Predictivo</b> | 2          | La disponibilidad histórica predice la disponibilidad futura solo en ausencia de cambios significativos. Útil para tendencias, menos para eventos disruptivos como ataques o fallos mayores. |
| <b>R Relevante</b>  | 3          | La métrica más intuitiva para el Consejo. DORA Art. 8(6), SOC 2 y ISO 27001 la exigen. El impacto de inactividad en euros/hora la hace directamente relevante para CFO y CEO.                |
| <b>A Accionable</b> | 3          | Uptime < 99% → análisis de causas raíz, inversión en redundancia/HA. SLA Compliance < 100% → revisión de compromisos contractuales o mejora técnica.                                         |
| <b>G Genuino</b>    | 3          | El uptime es uno de los indicadores más genuinos: o el servicio responde o no responde. Los sistemas de monitoring lo detectan con alta fidelidad.                                           |
| <b>M Medurable</b>  | 3          | Toda plataforma de monitorización (Prometheus, Datadog, Nagios) genera uptime con precisión automática. Sin coste adicional de medición.                                                     |
| <b>A2 Preciso</b>   | 3          | El uptime es objetivo y precisamente medible. La definición de "disponible" (¿respuesta con SLA de tiempo? ¿funcionalidad completa?) debe acordarse para evitar ambigüedades.                |
| <b>T Oportuno</b>   | 3          | Disponible en tiempo real. El dato más oportuno del conjunto de indicadores.                                                                                                                 |

|                        |       |                                                                                                                                                                    |
|------------------------|-------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>I Independiente</b> | 3     | Verificable mediante monitorización externa (servicios de uptime monitoring de terceros). Uno de los indicadores más independientemente verificables del conjunto. |
| <b>C Rentable</b>      | 3     | Coste de extracción: cero si ya existe monitorización. Incluso el coste de implementar monitorización básica es mínimo para el valor que genera.                   |
| <b>TOTAL</b>           | 26/27 | Clase A — Métrica de calidad óptima ★                                                                                                                              |

#### A-05: Índice de Resiliencia ante Ransomware (M-A05a-d)

| Criterio            | Puntuación | Justificación detallada                                                                                                                                                                                                      |
|---------------------|------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>P Predictivo</b> | 3          | Un Backup Isolation Score bajo predice directamente el impacto devastador de un ataque ransomware: backups conectados = backups cifrados = sin recuperación sin pago. Poder predictivo máximo sobre el resultado del ataque. |
| <b>R Relevante</b>  | 3          | Con 392 ataques ransomware en España en 2025 (INCIBE) y un coste de \$2,73M de media por ataque (Verizon), este indicador tiene relevancia estratégica directa.                                                              |
| <b>A Accionable</b> | 3          | Backup Isolation < 1 → desconexión inmediata de backups de la red de producción. Verification Rate < 100% → activar proceso mensual de restauración de test. Recovery Exercise = 0 → planificar ejercicio inmediato.         |
| <b>G Genuino</b>    | 2          | M-A05a (verificación) mide si la restauración funciona técnicamente, pero no si el RTO se alcanza en condiciones de desastre total. M-A05d (ratio ejercicio vs. RTO) es el más genuino.                                      |
| <b>M Medible</b>    | 3          | M-A05a y M-A05b son directamente observables. M-A05c y M-A05d requieren ejercicios planificados, que tienen coste pero son medibles.                                                                                         |
| <b>A2 Preciso</b>   | 2          | Las pruebas de restauración en entorno controlado tienen el sesgo de optimismo mencionado para A-03. La recuperación real puede ser más lenta por factores no replicados.                                                    |
| <b>T Oportuno</b>   | 3          | M-A05a mensual, M-A05b trimestral, M-A05c anual. La frecuencia anual para ejercicios completos es aceptable dada la complejidad.                                                                                             |

|                        |       |                                                                                                                                                                                               |
|------------------------|-------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>I Independiente</b> | 2     | Los registros de backup y los informes de ejercicios son verificables. La completitud del aislamiento (air-gap) requiere verificación física o técnica especializada.                         |
| <b>C Rentable</b>      | 2     | Los ejercicios de recuperación ransomware tienen coste operacional alto (tiempo técnico, entornos). Pero comparado con el coste de un ataque real no contenido (\$2,73M+), el ROI es inmenso. |
| <b>TOTAL</b>           | 23/27 | Clase B — Métrica de buena calidad                                                                                                                                                            |

**A-06: Parcheo de Dispositivos de Borde (M-A06a, M-A06b, M-A06c)**

| Criterio            | Puntuación | Justificación detallada                                                                                                                                                                                                                           |
|---------------------|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>P Predictivo</b> | 3          | El 54% de dispositivos de borde no estaban parcheados en el momento del ataque (Verizon DBIR 2025). La latencia de parcheo en borde es el predictor más potente de compromiso por vulnerabilidad de borde.                                        |
| <b>R Relevante</b>  | 3          | El incremento de 8× en exploits de edge/VPN (Verizon 2025) hace que este indicador sea crítico. CISA KEV es la fuente oficial de vulnerabilidades activamente explotadas.                                                                         |
| <b>A Accionable</b> | 3          | Patch Latency > 15 días → SLA de parcheo borde a 7 días.<br>Inventory Completeness < 100% → auditoría de red para identificar dispositivos no inventariados. KEV Monitoring < 100% → suscripción y monitorización automatizada del feed CISA KEV. |
| <b>G Genuino</b>    | 3          | Los tiempos de parcheo y la completitud del inventario son datos objetivos verificables. CISA KEV es una fuente externa objetiva. Alta genuinidad.                                                                                                |
| <b>M Measurable</b> | 3          | Con herramientas de gestión de red y vulnerability scanner, todas las métricas son calculables.                                                                                                                                                   |
| <b>A2 Preciso</b>   | 2          | La precisión depende de la completitud del inventario de borde. Dispositivos no inventariados no son medidos. En redes grandes con shadow IT de borde, la imprecisión puede ser significativa.                                                    |
| <b>T Oportuno</b>   | 3          | M-A06a semanal, M-A06b mensual, M-A06c semanal. Perfectamente adecuado para la dinámica de explotación de vulnerabilidades de borde.                                                                                                              |

|                        |       |                                                                                                                                                                                            |
|------------------------|-------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>I Independiente</b> | 2     | Verificable por auditor con acceso a la herramienta de gestión de red. CISA KEV es fuente pública independiente. La completitud del inventario es el punto de verificación más difícil.    |
| <b>C Rentable</b>      | 3     | El feed CISA KEV es gratuito. Las herramientas de inventario de red tienen coste moderado. El valor (prevención de compromiso de borde) es máximo dado el incremento de 8× en este vector. |
| <b>TOTAL</b>           | 25/27 | Clase A — Métrica de calidad óptima                                                                                                                                                        |

## EXTENSIONES CIANA

### AT-01: Trazabilidad de Sesiones Privilegiadas (M-AT01a, M-AT01b)

| Criterio               | Puntuación | Justificación detallada                                                                                                                                                                      |
|------------------------|------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>P Predictivo</b>    | 2          | La grabación de sesiones no predice ataques, pero predice la capacidad de investigación forense. Una baja cobertura predice incapacidad de reconstruir la cadena de custodia post-incidente. |
| <b>R Relevante</b>     | 3          | ENS Trazabilidad, DORA Art. 13(7) y NIS2 exigen trazabilidad de acciones privilegiadas. Requerimiento explícito para auditorías de cumplimiento.                                             |
| <b>A Accionable</b>    | 3          | Recording Rate < 90% → ampliar cobertura PAM a sesiones no capturadas.<br>Integrity Score = 0 → implementar almacenamiento inmutable para grabaciones.                                       |
| <b>G Genuino</b>       | 3          | La grabación de sesiones captura exactamente lo que el usuario privilegiado hizo. Es el control forense más genuino disponible.                                                              |
| <b>M Measurable</b>    | 3          | Las herramientas PAM generan estadísticas de cobertura de grabación de forma nativa.                                                                                                         |
| <b>A2 Preciso</b>      | 3          | La cobertura es binaria y objetiva. La integridad de los registros es verificable mediante hash/timestamping.                                                                                |
| <b>T Oportuno</b>      | 3          | Mensual para cobertura, trimestral para integridad. Adecuado.                                                                                                                                |
| <b>I Independiente</b> | 2          | Los registros de sesiones son verificables. Sin embargo, un administrador PAM con suficientes privilegios podría eliminar grabaciones si el almacenamiento no es verdaderamente inmutable.   |

|                   |       |                                                                                                                                                                                         |
|-------------------|-------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>C Rentable</b> | 2     | El coste de la solución PAM con grabación es significativo. Una vez implementada, el coste marginal de la métrica es mínimo. El valor forense y de cumplimiento justifica la inversión. |
| <b>TOTAL</b>      | 24/27 | Clase A — Métrica de calidad óptima                                                                                                                                                     |

AT-02: Índice de Cultura de Seguridad (M-AT02a-d)

| Criterio            | Puntuación | Justificación detallada                                                                                                                                                                                                                       |
|---------------------|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>P Predictivo</b> | 3          | La Phishing Click Rate es uno de los mejores predictores de probabilidad de éxito de ataques de ingeniería social. Organizaciones con tasa > 20% tienen 4× más probabilidad de brecha con componente humano (KnowBe4 State of Phishing 2025). |
| <b>R Relevante</b>  | 3          | El 60% de brechas con componente humano (Verizon 2025) hacen que este sea uno de los indicadores más relevantes del conjunto. NIS2 Art. 20(2) exige formación de directivos.                                                                  |
| <b>A Accionable</b> | 3          | Click Rate > 20% → formación de emergencia y simulacros adicionales. Training Completion < 70% → campañas de refuerzo con gestión directiva. Executive Compliance < 100% → escalado a órgano directivo (NIS2 exigencia).                      |
| <b>G Genuino</b>    | 2          | Los simulacros de phishing miden la vulnerabilidad en condiciones de prueba, que puede diferir del comportamiento real ante un phishing sofisticado real. La cultura no es directamente medible; solo sus proxies.                            |
| <b>M Medurable</b>  | 3          | Las plataformas de awareness (KnowBe4, Proofpoint SAT) generan todas estas métricas de forma automática.                                                                                                                                      |
| <b>A2 Preciso</b>   | 2          | La tasa de clics en simulacro puede estar influenciada por el diseño del simulacro (más fácil → más clics, más difícil → menos pero no más seguro). La comparabilidad entre organizaciones requiere estandarización del diseño.               |

|                        |       |                                                                                                                                                                                                      |
|------------------------|-------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>T Oportuno</b>      | 3     | Trimestral para simulacros, anual para formación. Adecuado para la dinámica de comportamiento humano.                                                                                                |
| <b>I Independiente</b> | 2     | Verificable por auditor con acceso a la plataforma de awareness. Los resultados pueden estar influenciados por el tiempo de notificación previa al simulacro.                                        |
| <b>C Rentable</b>      | 3     | Las plataformas de awareness tienen coste bajo-medio. El ROI es altísimo dado que el factor humano causa el 60% de las brechas y el coste de la formación es una fracción del coste de un incidente. |
| <b>TOTAL</b>           | 24/27 | Clase A — Métrica de calidad óptima                                                                                                                                                                  |

AT-03: Índice de Madurez Zero Trust (M-AT03a, M-AT03b, M-AT03c)

| Criterio            | Puntuación | Justificación detallada                                                                                                                                                                                                                                      |
|---------------------|------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>P Predictivo</b> | 2          | El nivel de madurez ZT no predice directamente incidentes, pero se correlaciona negativamente con el impacto cuando ocurren: organizaciones con ZT avanzado reducen el coste de brecha en \$1,76M (IBM 2025).                                                |
| <b>R Relevante</b>  | 3          | Zero Trust es el paradigma de seguridad de referencia para 2025-2027. NIST SP 1800-35 (junio 2025), CISA y la estrategia nacional de ciberseguridad americana lo consolidan como marco de referencia.                                                        |
| <b>A Accionable</b> | 2          | El nivel CISA ZT genera una hoja de ruta, pero la implementación de ZT es un proyecto multi-año complejo que no tiene acciones inmediatas simples para cada valor de la métrica.                                                                             |
| <b>G Genuino</b>    | 1          | El nivel de madurez ZT es el indicador menos genuino del conjunto. Es una autoevaluación contra un modelo descriptivo, sujeta a interpretación y sesgo de autocomplacencia. La validez de la puntuación depende críticamente de quién realiza la evaluación. |
| <b>M Medurable</b>  | 2          | La herramienta CISA ZT Assessment es gratuita y aplicable. M-AT03b y M-AT03c son más objetivamente medibles que M-AT03a.                                                                                                                                     |
| <b>A2 Preciso</b>   | 1          | La evaluación de madurez ZT en escala 0-3 tiene imprecisión intrínseca. Los modelos descriptivos de madurez tienen una precisión inherentemente baja comparada con métricas técnicas.                                                                        |

|                        |       |                                                                                                                                                                                                     |
|------------------------|-------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>T Oportuno</b>      | 3     | Semestral es adecuado para un indicador estratégico de madurez arquitectural.                                                                                                                       |
| <b>I Independiente</b> | 1     | La autoevaluación ZT es por definición no independiente. Una evaluación realmente independiente requiere un auditor externo con expertise en arquitecturas ZT, lo que tiene un coste significativo. |
| <b>C Rentable</b>      | 2     | La herramienta CISA es gratuita. Una evaluación independiente es costosa. M-AT03b y M-AT03c tienen buena relación coste-beneficio.                                                                  |
| <b>TOTAL</b>           | 17/27 | Clase C — Métrica aceptable con reservas                                                                                                                                                            |

**Nota crítica y constructiva:** La puntuación de Clase C de ZT Maturity no es una recomendación para eliminarlo, sino para complementarlo con métricas más objetivas. M-AT03b (microsegmentación) y M-AT03c (autenticación continua) son más genuinas e independientes que M-AT03a (madurez auto-declarada). Recomendación: usar las tres juntas y dar más peso a las sub-métricas técnicas.

## RESUMEN EJECUTIVO: RANKING PRAGMATIC DE LOS 22 INDICADORES

| Posición                                                                            | Indicador                     | Pilar | Score PRAGMATIC | Clase                                                                                 | Nota destacada                          |
|-------------------------------------------------------------------------------------|-------------------------------|-------|-----------------|---------------------------------------------------------------------------------------|-----------------------------------------|
|  1 | I-02: TMPVC (Parcheo crítico) | I     | 26/27           | A  | Predictor más potente de explotación    |
|  1 | I-04: Firma Digital           | I     | 26/27           | A  | Máxima independencia por eIDAS          |
|  1 | A-02: MTTR/MTTC               | A     | 26/27           | A  | Requisito regulatorio directo NIS2/DORA |
|  1 | A-04: Uptime de Servicios     | A     | 26/27           | A  | Más oportuno e independiente del set    |
| 5                                                                                   | C-01: Cobertura MFA           | C     | 25/27           | A                                                                                     | Preventivo; vector #1 de brecha         |
| 5                                                                                   | I-01: FIM Coverage            | I     | 25/27           | A                                                                                     | Más genuino de integridad               |
| 5                                                                                   | A-06: Parcheo Borde           | A     | 25/27           | A                                                                                     | 8× incremento vector borde 2025         |
| 8                                                                                   | A-01: MTDD                    | A     | 24/27           | A                                                                                     | Referencia global IBM/Verizon           |
| 8                                                                                   | A-03: RTO/RPO Compliance      | A     | 24/27           | A                                                                                     | Predictor resiliencia real              |
| 8                                                                                   | AT-01: Trazabilidad Sesiones  | CIANA | 24/27           | A                                                                                     | Control forense más genuino             |
| 8                                                                                   | AT-02: Cultura de Seguridad   | CIANA | 24/27           | A                                                                                     | 60% brechas factor humano               |
| 12                                                                                  | A-05: Resiliencia Ransomware  | A     | 23/27           | B                                                                                     | Alta relevancia con 392 ataques ES 2025 |
| 13                                                                                  | C-02: Madurez IAM             | C     | 22/27           | B                                                                                     | Mejora con herramienta IGA              |

|    |                              |       |       |   |                                                |
|----|------------------------------|-------|-------|---|------------------------------------------------|
| 13 | C-05: DLP Coverage           | C     | 22/27 | B | Depende de clasificación previa de datos       |
| 13 | I-05: Integridad Logs        | I     | 22/27 | B | Clave para capacidad forense                   |
| 16 | C-03: Cifrado en Reposo      | C     | 20/27 | B | Requiere CSPM/DSPM para precisión              |
| 16 | I-03: Supply Chain Integrity | I     | 20/27 | B | Urgente por EU CRA 2027                        |
| 18 | C-04: Cripto-Agilidad PQC    | C     | 19/27 | B | El más forward-looking; precisión limitada hoy |
| 18 | C-06: Gobernanza Shadow AI   | C     | 19/27 | B | Genuinidad limitada por naturaleza del objeto  |
| 20 | AT-03: Zero Trust Maturity   | CIANA | 17/27 | C | Complementar con métricas técnicas ZT          |

## ANÁLISIS DE PATRONES: ¿QUÉ DICEN LOS RESULTADOS?

### Fortalezas del conjunto

Los indicadores de **mayor puntuación PRAGMATIC** comparten estas características:

- Datos objetivos y verificables (timestamps, certificados, logs de sistema)
- Fuentes externas de referencia (NVD/CVE, CISA KEV, eIDAS TSP)
- Impacto regulatorio directo con sanciones (NIS2, DORA)
- Herramientas estándar de extracción ya presentes en la mayoría de organizaciones

### Áreas de tensión sistémica

Los indicadores de **menor puntuación PRAGMATIC** revelan tres limitaciones estructurales de la medición de ciberseguridad:

1. El problema del shadow: Lo que no es visible no es medible (Shadow AI, inventario incompleto).  
Solución: combinar detección técnica con auditorías declarativas.
2. El problema de la autoevaluación: Los modelos de madurez auto-declarados (ZT Maturity) tienen sesgos inherentes. Solución: priorizar sub-métricas técnicas objetivas dentro del modelo de madurez.
3. El problema del horizonte temporal: Los indicadores predictivos de largo plazo (PQC) son menos precisos en el presente pero más valiosos estratégicamente. Solución: aceptar la imprecisión como característica, no como defecto.

### Recomendación de implementación por madurez

#### **Nivel 1 (Empezar por aquí — organizaciones sin sistema de métricas):**

I-02 (TMPVC), C-01 (MFA), A-04 (Uptime), A-01 (MTTD), AT-02 (Phishing Rate)

#### **Nivel 2 (Consolidación):**

A-03 (RTO/RPO), I-01 (FIM), A-02 (MTTR), AT-01 (Sesiones privilegiadas), I-05 (Logs)

#### **Nivel 3 (Madurez avanzada):**

C-02 (IAM), C-03 (Cifrado), C-05 (DLP), I-04 (Firma digital), A-05 (Ransomware), A-06 (Borde)

#### **Nivel 4 (Liderazgo):**

I-03 (Supply Chain), C-04 (PQC), C-06 (Shadow AI), AT-03 (Zero Trust)

*Matriz PRAGMATIC CIA Triad v2025 · Referencias: Brotby & Hinson, "A Practical Introduction to Information Security Measurement" (2013); ISACA Security Metrics Guidelines; NIST SP 800-55 R1; IBM Cost of Data Breach 2025; Verizon DBIR 2025; KnowBe4 State of Phishing 2025*